INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC103 Risk Assessment and Management Techniques

Technical Risk Treatment Lab

Northbridge Services: Report on Risk Treatment Analysis and Lab Status

Author: Adaeze Elizabeth Adeteye

Date: 8 November 2026

Status of this submission

The hands-on lab could not be built. I was unable to download Ubuntu Server 24.04 LTS because the free storage on my device is limited and could not hold the ISO and the virtual machine disks the lab requires.

No lab commands were run, and this report contains no command outputs, logs, hashes, timings or screenshots. None have been created or simulated. All controls are described as designed but untested.

1. Statement of limitation

The brief requires a local two-VM lab (Ubuntu Server 24.04 LTS and Kali Linux, each with 2 vCPUs, 2 to 4 GB RAM and a 25 GB disk) and states that a written recommendation alone does not satisfy the implementation tasks. I was not able to meet that requirement.

What happened

- The Ubuntu Server image could not be downloaded because my device does not have enough free storage for the ISO plus the virtual disks for two machines.
- Without the Ubuntu server, I could not run Steps 1 to 10 (baseline, avoidance, archive hardening, firewall restriction, log correlation, backup and restore).
- I did not substitute invented results. The brief states that marks depend on evidenced results, and I would rather submit an honest partial report than present anything as evidence that I did not collect.

What is included instead

- A proposed baseline risk register (R1 to R4), clearly marked as analyst estimates that were not confirmed by scans.
- Reasoned treatment decisions for avoidance, mitigation, transfer and acceptance, with the technical explanations the brief asks for.
- A monitoring plan, a first-year cost comparison and the illustrative ALE calculation, with every assumption labelled.
- A workbook with an evidence log template, a residual risk register and a recovery time calculator, and a runbook that lets the lab be completed quickly once an environment is available.

Requested support

I am requesting guidance from my course contact on whether an alternative is available, such as a pre-built Ubuntu Server VM image, access to a lab machine, or additional time. If the environment becomes available, I will complete Steps 1 to 10 and update the repository with genuine evidence.

2. Evidence status

Step	Task	Status	Evidence
1-3	Build Ubuntu environment, legacy service, Nginx site	Not performed	None
4	Baseline scans and requests from Kali	Not performed	None
5	Baseline risk register R1 to R4	Proposed (estimates)	This report; workbook
6	Avoidance: retire legacy service	Not performed	None (change record drafted)
7	Archive hardening, 200/403 checks	Not performed	None
8	UFW restriction, blocked-source test	Not performed	None
9	Log correlation	Not performed	None
10	Backup, delete, restore, recovery time	Not performed	None
11	Transfer and acceptance decisions	Analysis complete	This report
12	Cost comparison and ALE	Analysis complete (assumptions)	This report; workbook

3. Baseline risk register (proposed)

The brief's scale is used: likelihood 1 to 5, impact 1 to 5, score = likelihood x impact; bands 1 to 4 Low, 5 to 9 Medium, 10 to 16 High, 17 to 25 Critical. These are classroom thresholds, not an external standard, and scores are ordinal: they are not monetary loss or statistical probabilities.

The values below are my estimates from the lab design in the brief. The weaknesses are what the design is expected to contain; they were not observed, because no baseline was collected.

ID	Asset	Threat event	Expected weakness (not observed)	Imp.	Lik.	Score	Band	Evidence ref. (pending)
R1	Legacy HTTP endpoint (port 8080)	Unauthorised access to unneeded service	Unnecessary service listening on all interfaces	3	4	12	High	baseline-ports.txt; baseline-legacy.txt
R2	Archive of dummy records	Unauthorised file retrieval	Listing and direct file access enabled	4	4	16	High	baseline-listing.txt; baseline-file.txt
R3	Server network exposure	Unauthorised network access	No source restriction on inbound traffic	4	3	12	High	ufw status; ss -lntp
R4	Approved portal content	Loss or deletion of content	No tested backup or restore process	3	3	9	Medium	Recovery test evidence

Treatment owners (simulated): R1 service owner; R2 application owner; R3 infrastructure owner; R4 service owner.

Residual risk: not assessed. Residual likelihood, impact and score must rest on tested control outcomes, and no tests were run. Every control is therefore recorded as untested, not as effective.

4. Treatment decisions

4.1 Avoidance: retire the legacy endpoint (R1)

- Proposed change: disable the grc-legacy service and retain the approved portal.
- Business impact: none expected, since the endpoint is unused and holds dummy data only. Not confirmed by test.
- Approval role: service owner (approval simulated).
- Test: rescan ports 80 and 8080 from Kali; 8080 should no longer respond while port 80 still serves the portal.
- Rollback: sudo systemctl enable --now grc-legacy; then reapply the treatment and leave the endpoint disabled.

Why this does not eliminate all risk. Retiring the legacy workflow removes the exposure created by that service only. The remaining web service, its configuration, access controls and data still carry risk (R2, R3 and R4).

Result: not performed.

4.2 Mitigation: archive hardening and firewall restriction (R2, R3)

The design moves the archive outside the web root, restricts its permissions, denies the old URL in Nginx, and uses UFW to allow only the approved Kali address to reach port 80.

Listing versus direct access. Turning directory listing off only stops people browsing a directory. If the file is still inside the web root, anyone who knows or guesses its path can still request it directly. Moving the file out of the web root and denying the path removes publication itself.

Expected outcomes (from the brief, not observed): /public/ returns 200; /, /archive/ and the dummy file return 403; an approved source receives the portal; an unapproved source times out. A timeout alone is not sufficient proof, so UFW rule output and corroborating firewall logs would be retained.

Result: not performed. The controls are designed but untested.

4.3 Detection: log correlation

Permitted requests would appear in the Nginx access log. Traffic blocked by UFW is dropped in the kernel firewall before it reaches Nginx, so it should not appear in the Nginx log, although it may appear as UFW BLOCK entries (firewall logging can be rate-limited). If events were missing, I would document the collection problem and mark the control unverified, not failed, and I would not fabricate entries.

Result: not performed.

4.4 Correction: backup and restore (R4)

The design takes a protected archive of the portal directory plus a SHA-256 hash, deletes the file, confirms the service check fails, restores the archive, verifies the hash and confirms service again, recording start and end times to calculate recovery time.

Limitation. A same-host backup is useful for this exercise but does not protect against complete host loss, disk failure or compromise of the server.

Result: not performed; recovery time not measured.

5. Transfer and acceptance

5.1 Transfer: fictional managed-backup offer

Comparison: $120 setup plus $20 per month against local-only backup.

Item	Position
Provider duties	Store backups offsite, keep the service available, retain backup data for the agreed period, report failed backups.
Retained customer duties	Decide what is backed up, protect credentials, perform restoration tests, keep evidence, remain responsible for the data.
Restoration-test requirement	Restore tested at least quarterly and after significant change, with the result recorded.
Evidence retention	Backup job logs and restoration-test records kept for a defined period (proposed: 12 months).
Service limitation	The provider is not responsible for data that was never backed up or for errors caused by the customer.

Proposed service clause: *"The Provider shall perform scheduled backups of the Customer's designated portal content, store them offsite and notify the Customer of any failed job within one business day. The Customer remains responsible for selecting the content to be backed up, safeguarding access credentials and verifying restoration at least quarterly. The Provider's obligations apply only to content included in the backup scope."*

A contract or insurance does not remove the technical risk. The customer must still test restoration and remain in control of the data. No purchase is made.

5.2 Acceptance: plain HTTP on the isolated lab network, dummy data only

Field	Entry
Owner	Service owner (simulated)
Proposed residual risk score	Likelihood 2 x Impact 2 = 4 (Low). Analyst estimate, untested.
Rationale	Isolated host-only network, fictional data, no external connectivity.
Proposed expiry	14 days from approval
Review date	Day 14, or earlier if a trigger occurs
Triggers	Any real data; any external connectivity or bridged networking; wider user access; use beyond the lab.
Approval	Simulated

If any trigger occurs, the acceptance lapses and the matter should be escalated or treated (for example by deploying TLS) rather than accepted.

6. Cost comparison and remaining risk

First-year cost = setup + labour + annual recurring cost. All figures are fictional values from the brief.

Option	Calculation	First-year cost	Combination
A: Hardening	4 hours x $25 + $50 annual maintenance	$150	A + C = $250
B: Managed backup	$120 setup + ($20 x 12 months)	$360	A + B = $510
C: TLS	3 hours x $25 + $25 annual maintenance	$100	A + B + C = $610

Excluded costs: staff time beyond the stated hours, training, hardware or hosting, monitoring tools, incident and downtime costs, and later contract renewal.

Provisional recommendation: Options A and C address the weaknesses identified (exposure and plain-text transport) for $250 in the first year. Option B is justified by the illustrative ALE below and by the limits of a same-host backup, giving $610 if all three are adopted. This is provisional because the technical results needed to confirm it were not collected.

Illustrative ALE for Option B (all figures are assumptions)

Item	Calculation	Value
Annual rate of occurrence (assumption)	0.2	0.2 per year
Baseline ALE	0.2 x $5,000	$1,000
Residual ALE (loss reduced to $1,000, assumption)	0.2 x $1,000	$200
Annual benefit	$1,000 - $200	$800
First-year net benefit of Option B	$800 - $360	$440

These figures are assumptions. A recovery test, had it been run, would not establish them. Benefits from the options are not summed, and ordinal risk scores are not converted into dollars.

7. Monitoring and handover (proposed)

These checks are proposals for ongoing operation. They are not measured lab results.

Check	Owner (simulated)	Frequency	Threshold	Escalation
Approved portal availability	Service owner	Every 5 min (automated)	Failed for more than 15 minutes	Notify service owner; infrastructure lead after 1 hour
Unexpected open ports	Infrastructure owner	Daily scan	Any open port other than 80	Incident; review within 4 hours
Recovery-test success	Service owner	Quarterly	Restore fails or hash mismatch	Fix backup process; retest within 5 working days
Drift: retired legacy service	Infrastructure owner	Daily	grc-legacy active, enabled or on port 8080	Disable, record change, investigate cause

8. Next steps

- Obtain Ubuntu Server 24.04 LTS and Kali Linux (using external storage if needed) and take a clean checkpoint of each VM.
- Run Steps 1 to 10 using the runbook in the repository, saving every output with its timestamp.
- Complete the evidence log, replace pending evidence references, and reassess R1 to R4 from the actual results.
- Update this report and the management summary with real outcomes.

Management Summary (one page)

Purpose. Northbridge Services asked for measurable risk treatment of its document server without interrupting the approved web service.

Status. The technical lab could not be completed. Ubuntu Server could not be downloaded because of limited storage on the analyst's device. No control has been implemented or tested in this submission, and no technical evidence is claimed.

Risks identified (estimates, not confirmed by scans). R2 exposed archive (16, High); R1 unnecessary legacy service (12, High); R3 unauthorised network access (12, High); R4 loss of portal content (9, Medium).

Recommended treatments. Retire the legacy service (avoidance); move the archive out of the web root and restrict inbound traffic to approved sources (mitigation); test backup and restore (correction); consider a managed backup service while keeping restoration testing in-house (transfer); and accept plain HTTP only temporarily on the isolated network with dummy data, expiring after 14 days (acceptance, simulated approval).

Cost. Hardening $150, managed backup $360, TLS $100 in the first year (fictional). A + C costs $250; all three cost $610. Under the stated assumptions, the backup option shows a first-year net benefit of $440; these are assumptions, not measured values.

Residual risk. Not assessed, because no tests were run. All controls should be treated as designed but unverified.

Decisions needed. (1) Confirm whether an alternative environment or extension is available to complete the technical steps. (2) Once tested, review the residual risk scores and confirm the treatment combination.

Monitoring. Proposed checks cover portal availability, unexpected open ports, recovery-test success and drift of the retired legacy service, each with an owner, frequency, threshold and escalation path.